

Enterprise Information Security Policy

Semir Hot, Harrison Maksimik

March 5, 2024

Contents

1	Statement of Policy	1
1.1	Purpose	1
1.2	Scope	1
1.3	Authority	1
1.4	Responsibilities	2
2	Background Information	2
2.1	Need for information security	2
2.2	Objectives	2
3	Policy Compliance	3
3.1	Procedures for reporting violations	3
3.2	Penalties for violations	3
3.3	Exceptions	3
4	Policies and Procedures	3
4.1	Access control	3
4.2	Logging	4
4.3	Backups	4
4.4	Non-repudiation	4
5	References	4

1 Statement of Policy

1.1 Purpose

The purpose of this policy is to establish the basic security policies that should be observed organization-wide, assign responsibilities for maintaining

this and other security related documents in our organization, and to describe the structure of our security documentation. This document will also establish the rationalization for establishing information security.

1.2 Scope

The scope of this policy applies to all company data, information systems, networks, applications, personnel, contractors, and other workers at this Phillips 66 branch. All non-organization owned devices which connect to our network should also be subject to the policies and procedures listed in this document. Further details on specific systems and issues can be found in separate policies, though devices and systems which have no associated specific policy, and for which no reasonably applicable specific policy exists, should refer to the basic standards found in this document.

1.3 Authority

Unless otherwise stated by law, directives from executives, or specific policy, all procedures listed in this document and its sub-documents should be considered the final authority for all disputes over policy. All organization personnel, contractors, and other workers are required to understand and agree to the terms listed in these policies. Should this document or its sub-documents require modification, it is the duty of the Chief Information Security Officer (CISO) to amend any of these documents in a timely fashion.

1.4 Responsibilities

The responsibilities to uphold this policy extend to all stakeholders of our organization. All users of information assets and systems in our organization must read, understand, agree to, and uphold the requirements of this policy. It should be the responsibility of the Chief Information Security Officer (CISO), along with other parties of interest, to develop and maintain this issue-specific security policy. It should be the responsibility of line managers to enforce compliance with this policy among other personnel. Contractors who have access to information assets and systems must be held to the same requirements as well. It is, however, our organization's own duty to ensure that the use of third-party services is in compliance with our security policies.

2 Background Information

2.1 Need for information security

Our organization has seen a large increase in technology usage in the past decade. While new information systems have streamlined many business processes, it's important to consider, mitigate, and appropriately react to the new threats this technology presents to our business. In particular, the introduction of network attached devices has greatly improved the speed at which business can be done, but if these network devices are not properly secured, our organization could suffer destruction and or loss of data, which could be costly to resolve. Thus, in order to maintain adequate security and risk management processes, our organization must develop proper policies and specifications for each of our information assets. These policies should consider the impact of the asset on our organization's profitability, the reputational damage that could be caused from having that asset compromised, and the assets which are most expensive to replace, among other criteria.

2.2 Objectives

The primary goal of this policy is to ensure that the confidentiality, integrity, and availability of information in the organization is considered and properly managed. To ensure these objectives are reached, several general procedures will be listed in this document which should be considered de facto rules for information system security. Separate documents which provide policies for specific issues and systems will be assumed to inherit the general rules from this document, but will also be able to create new procedures and override the procedures from this document in certain cases.

3 Policy Compliance

3.1 Procedures for reporting violations

Should any employee witness a violation of this security policy, their line manager should be informed as soon as possible with adequate details describing the perceived violation of policy. If an employee feels uncomfortable reporting the issue to a line manager, or if a contractor or third-party worker wishes to report a security policy violation, an email can be sent to the security department containing all necessary information.

3.2 Penalties for violations

Violations of the policies listed in this document and/or other specific policy documents can result in disciplinary actions up to and including termination of employment. Issue specific policies will describe further the severity of the penalties for violating these policies.

3.3 Exceptions

Should any party to whom this policy applies be unable to fulfill the obligations of this policy, the CISO should be notified of the circumstances. In exceptional circumstances, this policy may be found inadequate for the purposes of providing availability, confidentiality or integrity of information. Working with the CISO to better understand and amend the inadequacies in the security policy can greatly expedite the improvement of our organization's policy. Hence, in order to submit good requests for exception, it's important to provide as much detail about the issue as possible.

4 Policies and Procedures

4.1 Access control

All systems connected to our organization's network should be subject to some level of access control. In general, this organization should adopt an access control model found in the issue-specific policy document which concerns access control. This access control model should not encumber business needs, and confidentiality needs should be assessed based on the criticality of the asset.

4.2 Logging

Our organization must ensure that proper logs are kept to ensure forensic readiness. In some cases of exploitation of our systems, it may be necessary to pursue legal remediation. Therefore, it is important that the logging system used is thoroughly tested, and legally admissible as evidence.

4.3 Backups

Backups of critical data should be kept in a reasonable fashion. Further details will be discussed in issue-specific and system-specific policies.

4.4 Non-repudiation

Our business relies on financial transactions with customers. It is therefore necessary to ensure that any transaction is well documented, and that steps to ensure non-repudiation are met. This may be handled internally or by third-party vendors; this will be determined by system-specific policy.

5 References

- <https://www.mass.gov/doc/is000-enterprise-information-security-policy/download>